CNS ALA-3 Cyber Decryption Chronicles

1. RSA SecurID Breach (2011)

Attack technique: Spear-phishing email + malicious attachment

What happened?

Attackers sent targeted emails to a small number of employees. An Excel attachment titled “2011 Recruitment Plan” exploited a software vulnerability and gave attackers a foothold in RSA’s network. Information related to SecurID two-factor authentication tokens was stolen.

Attack flow

Targeted email → employee opens attachment → malware runs → internal data accessed → SecurID-related information stolen

REAL NEWS / WIKIPEDIA IMAGE

Real-image source: Wikipedia article “RSA SecurID” (incident section). Open the source link below and use an actual editorial image from the article if available; do not substitute an AI-generated image.

How could it have been prevented?

- Train staff to recognize unexpected recruitment files and urgent attachments.
- Block or sandbox risky attachments and keep software patched.
- Use least-privilege access, endpoint detection, and network segmentation.
- Report suspicious emails quickly and investigate them centrally.

Kunal Sharma IST-323: Case Study – RSA Phishing and APT Attack
IST-323

In the modern-day business world that integrates computer networks into their operations more than ever before, attackers can use various methods to gain access to information systems. RSA Security LLC, an American computer and network security corporation, has many databases that require optimum network security, including cryptography libraries and the employees' user SecurID tokens. In 2011, these tokens acted as a two-factor authentication method for employees, by requiring users to enter a "secret code number displayed on a key fob, or in software" (Zetter), in addition to their username and password. This number was cryptographically generated and changed every 30 seconds, adding an extra layer of security. However, each token had a serial number on it to make it unique, and if an attacker were able to compromise the system, they could obtain the individual user information(Zetter). These network aspects can introduce various liabilities (especially when they rely on the defenses of supplemental end-user software like Adobe Flash ["RSA FraudAction Research Labs"] when

ı as cookies to enable essential site functionality, as well as for performance cookies, personali

2. Target Retail Breach (2013)

Attack technique: Third-party compromise / stolen vendor credentials

What happened?

Attackers obtained credentials associated with a heating, ventilation, and air-conditioning (HVAC) vendor, then used the vendor's access as a route into Target's network. Malware was later used to steal payment-card data from point-of-sale systems.

Attack flow

Vendor credentials compromised → vendor access misused → network access expanded → POS systems targeted → payment-card data stolen

REAL NEWS / WIKIPEDIA IMAGE

Real-image source: Wikipedia's Target Corporation data breach coverage and contemporary news reports. Use a genuine news photo or a relevant published image from the source page.

How could it have been prevented?

- Give vendors access only to the systems they need.
- Require multi-factor authentication for remote access.
- Monitor unusual vendor logins and movement between network segments.

- Separate point-of-sale systems from general corporate networks.



Dear Target Guest,

As you may have heard or read, Target learned in mid-December that criminals forced their way into our systems and took guest information, including debit and credit card data. Late last week, as part of our ongoing investigation, we learned that additional information, including name, mailing address, phone number or email address, was also taken. I am writing to make you aware that your name, mailing address, phone number or email address may have been taken during the intrusion.

I am truly sorry this incident occurred and sincerely regret any inconvenience it may cause you. Because we value you as a guest and your trust is important to us, Target is offering one year of free credit monitoring to all Target guests who shopped in U.S. stores, through Experian's® ProtectMyID® product which includes identity theft insurance where available. To receive your unique activation code for this service, please go to creditmonitoring.target.com and register before April 23, 2014. Activation codes must be redeemed by April 30, 2014.

In addition, to guard against possible scams, always be cautious about sharing personal information, such as Social Security numbers, passwords, user IDs and financial account information. Here are some tips that will help protect you:

- Never share information with anyone over the phone, email or text, even if they claim to be someone you know or do business with. Instead, ask for a call-back number.
- Delete texts immediately from numbers or names you don't recognize.
- Be wary of emails that ask for money or send you to suspicious websites. Don't click links within emails you don't recognize.

Target's email communication regarding this incident will never ask you to provide personal or sensitive information.

Thank you for your patience and loyalty to Target. You can find additional information and FAQs about this incident at our Target.com/databreach website. If you have further questions, you may call us at 866-852-8680.

Gregg Steinhafel

Chairman, President and CEO

3. Twitter/X Account Hijacking (2020)

Attack technique: Phone-based social engineering / spear-phishing

What happened?

Attackers manipulated Twitter employees who had access to internal support tools. They used employee information to target staff and obtained credentials that enabled access to internal systems. High-profile accounts were taken over and used to post a cryptocurrency scam.

Attack flow

Employee research → deceptive phone contact/fake login → staff credentials captured → internal tools accessed → accounts hijacked

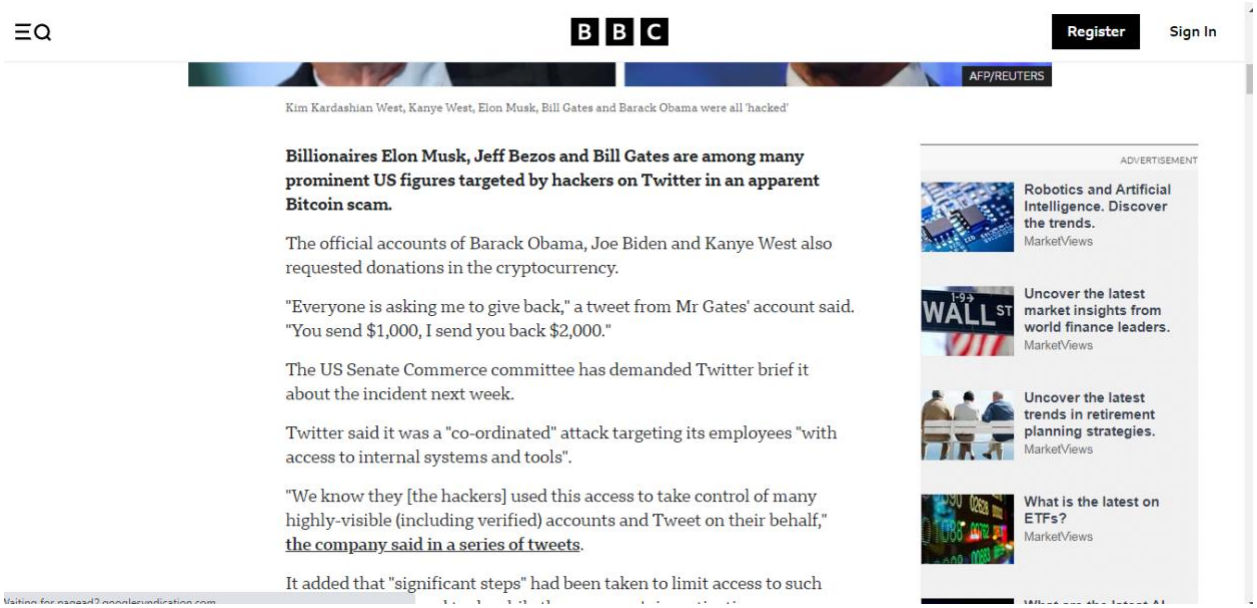
REAL NEWS / WIKIPEDIA IMAGE

Real-image source: Wikipedia's 2020 Twitter account hijacking article and its linked reporting. Use an authentic screenshot/photo published with the case, not an illustration generated for this report.

How could it have been prevented?

- Verify IT requests through a separate, trusted channel.

- Use phishing-resistant MFA such as security keys for staff accounts.
- Restrict and log access to powerful internal support tools.
- Train employees to never share one-time codes or approve unexpected prompts.



BBC

Register Sign In

AFP/REUTERS

Kim Kardashian West, Kanye West, Elon Musk, Bill Gates and Barack Obama were all 'hacked'

Billionaires Elon Musk, Jeff Bezos and Bill Gates are among many prominent US figures targeted by hackers on Twitter in an apparent Bitcoin scam.

The official accounts of Barack Obama, Joe Biden and Kanye West also requested donations in the cryptocurrency.

"Everyone is asking me to give back," a tweet from Mr Gates' account said. "You send $1,000, I send you back $2,000."

The US Senate Commerce committee has demanded Twitter brief it about the incident next week.

Twitter said it was a "co-ordinated" attack targeting its employees "with access to internal systems and tools".

"We know they [the hackers] used this access to take control of many highly-visible (including verified) accounts and Tweet on their behalf," the company said in a series of tweets.

It added that "significant steps" had been taken to limit access to such

ADVERTISEMENT

Robotics and Artificial Intelligence. Discover the trends.
MarketViews

Uncover the latest market insights from world finance leaders.
MarketViews

Uncover the latest trends in retirement planning strategies.
MarketViews

What is the latest on ETFs?
MarketViews

4. Uber Security Breach (2022)

Attack technique: Social engineering + multi-factor authentication fatigue

What happened?

An attacker with a contractor's compromised credentials repeatedly prompted the account holder with authentication requests and contacted them through messaging. The incident gave the attacker access to internal systems and exposed internal information, though Uber said sensitive customer and driver data was not directly stolen in the incident.

Attack flow

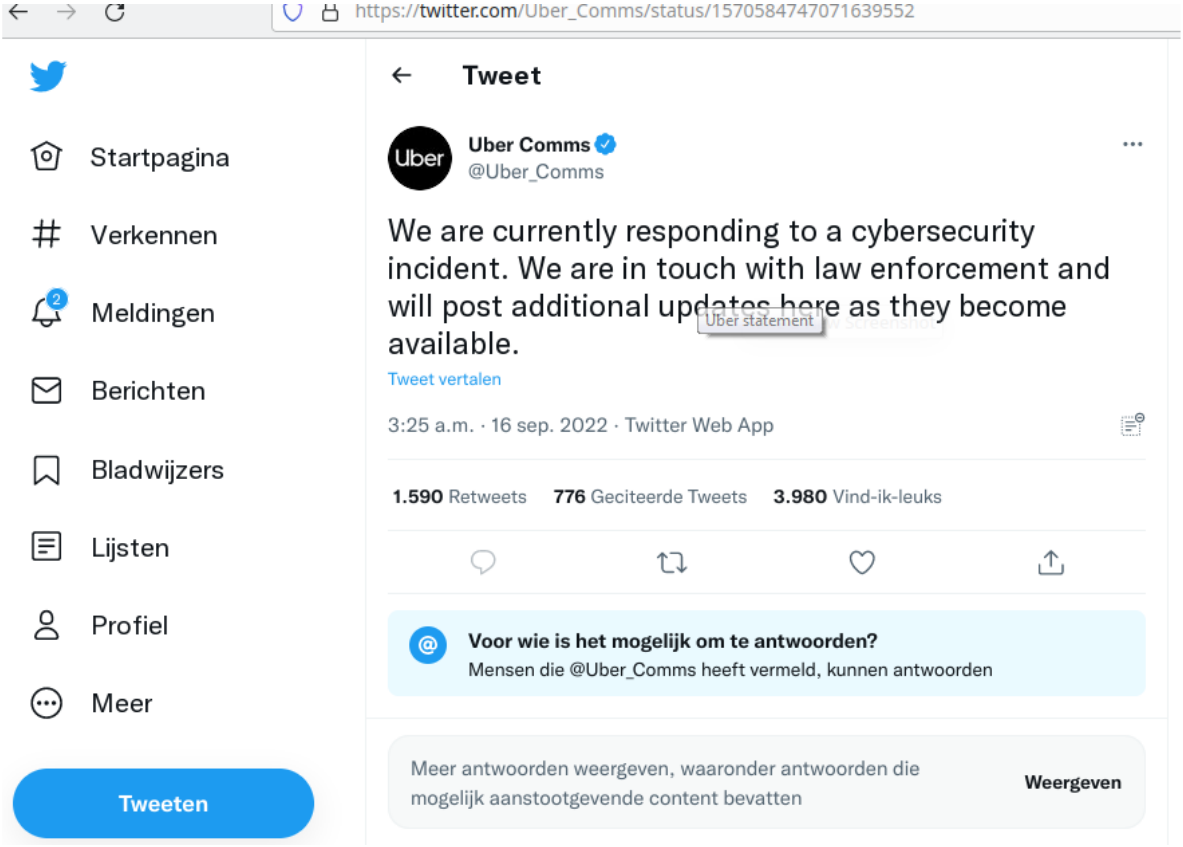
Credentials obtained → repeated MFA prompts/messages → account access gained → internal tools accessed → systems investigated and secured

REAL NEWS / WIKIPEDIA IMAGE

Real-image source: contemporary news coverage of the 2022 Uber breach; the linked Wikipedia data-breach list provides a starting point to find the incident and its cited reporting.

How could it have been prevented?

- Use number-matching or phishing-resistant MFA and limit repeated prompts.
- Never approve an unexpected login request; report it immediately.
- Keep credentials out of scripts, shared drives, and internal chat.
- Use conditional access and alert on unusual authentication patterns.



5. MGM Resorts Cyberattack (2023)

Attack technique: Vishing (voice phishing) + employee impersonation

What happened?

Attackers reportedly researched an employee using publicly available information, then called the IT help desk and impersonated that employee. The help desk was tricked into helping them gain account access. The incident disrupted hotel and casino systems, including digital room keys, payments, and slot machines.

Attack flow

Employee details researched → fake identity used in help-desk call → account access obtained → internal systems disrupted → business operations affected

REAL NEWS / WIKIPEDIA IMAGE

Real news photo available in TechCrunch's report: betting kiosks at MGM Grand shown offline, credited to K.M. Cannon / Las Vegas Review-Journal / Getty Images. Open the article to view and cite the original image.

How could it have been prevented?

- Verify identity with a strong procedure before resetting accounts or MFA.
- Require approval for sensitive access resets and notify the real employee.
- Use phishing-resistant MFA and separate admin accounts.
- Prepare incident-response plans and offline procedures for critical services.



Common lessons

- Verify identity before sharing information, resetting passwords, or changing MFA settings.
- Treat unexpected links, attachments, phone calls, and authentication prompts with caution.
- Use multi-factor authentication, preferably phishing-resistant methods such as security keys.
- Limit permissions and separate sensitive systems from everyday user networks.
- Report suspicious activity immediately; quick reporting can reduce damage.